



AETHERUM, INC.

Operational Security Procedures

Signing Flow · Threshold Configuration · Escalation Runbook · Incident Response

Version 1.0 · Issued May 27, 2026 · CONFIDENTIAL — For Institutional Review Only

About This Document — This document describes Aetherum's operational security procedures for credit union partners and their infosec, risk, and compliance teams. It covers the signing flow and key management architecture, LTV threshold configuration procedures, liquidation escalation runbook, and incident response procedures. This document is intended to satisfy vendor security review requirements including SIG questionnaire domains S (Encryption & Key Management), H (Incident Response), and I (Operational Resilience).

Aetherum's Role — Aetherum is a B2B software vendor, not a financial institution. The platform operates as a software orchestration layer. All digital asset custody, key management, and signing authority rests exclusively with the credit union through its own direct custody provider account. Aetherum accesses custody infrastructure via API only — it never holds, controls, or has signing authority over any digital asset wallet.

01 — SIGNING FLOW & KEY MANAGEMENT

1.1 Key Custody Architecture

Each credit union partner holds its own independent, direct custody provider account. Digital asset private keys are generated, stored, and managed exclusively within the custody provider's enterprise key management infrastructure — an NYDFS-licensed, SOC 2-audited institutional custodian.

Aetherum does not:

- Generate, hold, or store any digital asset private keys
- Have signing authority over any credit union's digital asset wallet
- Access custody infrastructure except via authenticated API calls
- Retain credentials that would allow independent transaction execution

The credit union owns custody directly. Aetherum provides the software layer that instructs the custody provider to execute transactions — but execution requires the



custody provider's own key management infrastructure to authorize the transaction independently.

1.2 Signing Flow — Liquidation Execution

The liquidation signing flow follows this sequence:

Step	System	Action
1	Glacient / Monitor	LTV breach detected — webhook fired to Aetherum with HMAC-SHA256 signature
2	Aetherum Backend	HMAC signature validated — unauthenticated webhooks rejected (HTTP 401)
3	Aetherum Backend	Escalation tier determined (Tier 1/2/3) based on loan balance and market volatility
4a	Tier 1 — Auto	Liquidation instruction sent to custody provider via Trading API — market sell executed
4b	Tier 2 — Notify	Liquidation queued — SMS + email sent to CU risk officer — 30-min countdown — auto-executes at expiry if no override
4c	Tier 3 — Human	Liquidation paused completely — explicit human authorization required via POST /liquidation/authorize before any execution
5	Custody Provider	Market sell executed via custody provider's direct exchange integrations — 24/7
6	Aetherum Backend	AetherumAuditTrail on-chain attestation logged — immutable record of liquidation event

1.3 Key Rotation

Digital asset private key rotation is managed entirely by the custody provider's enterprise key management infrastructure. The custody provider maintains documented key rotation procedures as part of its NYDFS licensing requirements and SOC 2 audit scope.

Aetherum application secrets (JWT signing keys, HMAC webhook secrets, API credentials) are stored as Railway environment variables — not in codebase. Rotation procedure:

- New secret generated out-of-band
- Secret updated in Railway environment variables
- Service redeployed — new secret takes effect on next request
- Old secret retired — no grace period for webhook secrets (immediate rotation)



1.4 Multi-Signature Controls

The custody provider applies multi-signature authorization natively at the wallet infrastructure layer for large transactions. This operates independently of Ethereum's liquidation trigger — it is a custody-layer security control, not an application-layer approval step. The credit union configures multi-sig thresholds directly with the custody provider as part of account setup.

02 — THRESHOLD CONFIGURATION PROCEDURES

2.1 LTV Threshold Setting at Loan Origination

Maximum LTV thresholds are set per loan at origination by the DACS (Dynamic Asset Collateral Score) risk model. The process:

- Member submits loan application via the credit union's member portal
- DACS model scores the collateral asset across 6 pillars: market volatility, on-chain wallet health, asset liquidity, protocol risk, borrower behavioral patterns, and tax position exposure (TPSOE)
- DACS composite score maps to a maximum LTV tier: Tier 1 (highest score) = up to 70% LTV; Tier 2 = up to 65% LTV; Tier 3 = up to 55% LTV
- Maximum LTV is stored on the loan record in MongoDB at origination
- Native LTV monitoring service reads the stored maxLtv field on each polling cycle

2.2 Warning Threshold Configuration

The warning threshold — the LTV level at which pre-breach alerts fire — is configurable via Railway environment variable:

Variable	Default	Effect
MONITOR_WARNING_PCT	0.80	Warning fires at 80% of maxLtv — e.g. if maxLtv = 75%, warning fires at 60% LTV
MONITOR_INTERVAL_SECONDS	60	Polling interval in seconds — wallets checked every 60 seconds

Threshold changes require: (1) update to Railway environment variable, (2) service redeploy, (3) change logged in deployment audit trail. No application code changes required for threshold adjustments.



2.3 Escalation Tier Thresholds

The three-tier escalation thresholds are configurable per deployment:

Tier	Loan Balance Trigger	Volatility Trigger	Behavior
Tier 1	Under \$50,000	1-hr drop under 20%	Auto-execute — no human required
Tier 2	\$50,000 – \$250,000	1-hr drop 20%–40%	Notify + 30-min delay — auto-executes if no override
Tier 3	Over \$250,000	1-hr drop over 40% OR BitGo retries exhausted	PAUSED — explicit human authorization required

03 — ESCALATION RUNBOOK

3.1 Tier 2 — Notify & Delay Runbook

Trigger condition: Loan balance \$50K–\$250K OR 1-hour price drop 20%–40%

Automated actions (no human required):

- Liquidation queued in MongoDB — status set to liquidation_queued
- SMS alert sent via Twilio to CU risk officer phone (ALERT_RISK_OFFICER_PHONE)
- SMS alert sent to Aetherum ops (ALERT_OPS_PHONE)
- Email alert sent via SendGrid to CU risk officer and Aetherum ops
- 30-minute countdown timer started — autoExecuteAt timestamp set on LiquidationEvent
- Loan Officer Dashboard shows live countdown with Approve / Reject buttons

Human override options (within 30-minute window):

- APPROVE: POST /liquidation/override { eventId, action: 'approve' } — liquidation executes immediately
- REJECT: POST /liquidation/override { eventId, action: 'reject' } — liquidation cancelled, loan officer assumes manual monitoring
- NO ACTION: At autoExecuteAt timestamp — liquidation executes automatically



3.2 Tier 3 — Human Required Runbook

Trigger condition: Loan balance over \$250K OR 1-hour price drop over 40% OR BitGo Trading API retries exhausted (3x exponential backoff: 1s, 2s, 4s)

Automated actions:

- Liquidation PAUSED — no auto-execution under any conditions
- Sentry FATAL alert fired immediately with full context (loanId, escalationTier, priceDropPct1h)
- SMS + email to CU risk officer AND Aetherum ops
- Loan Officer Dashboard header turns red — Tier 3 banner visible to all loan officers
- escalationStatus set to 'paused' — system will not proceed without explicit authorization

Required human action:

- Authorized loan officer or CU risk officer must call: POST /liquidation/authorize { eventId }
- JWT authentication required — only users with loan officer or risk officer role can authorize
- Authorization logged with userId, timestamp, and action for NCUA audit trail
- After authorization — liquidation executes via custody provider Trading API

If BitGo retries exhausted (Tier 3 trigger):

- Contact custody provider support directly
- Do not re-attempt via Aetherum until custody provider confirms API availability
- Document all manual steps in the LiquidationEvent record via POST /liquidation/events/:id/notes

04 — INCIDENT RESPONSE PROCEDURES

4.1 Incident Classification

Severity	Trigger	Response
P0 — Critical	Custody provider API unavailable during active liquidation	Tier 3 auto-escalation → Sentry FATAL → immediate human authorization required → direct custody provider contact



P1 — High	LTV monitoring service down; Railway service failure; unauthorized webhook attempt	Sentry alert → ops notification → Railway redeploy → incident logged
P2 — Medium	Price feed cache miss; Tier 2 notification delivery failure; elevated latency	Automated retry → Sentry warning → ops review within 4 hours
P3 — Low	Non-critical dependency warning; elevated error rate below threshold	Sentry logging → ops review at next business day

4.2 P0 Response Procedure — Custody Provider Unavailable

- Step 1: Aetherum backend detects BitGo API failure after 3x exponential backoff (1s, 2s, 4s)
- Step 2: Tier 3 escalation triggered automatically — all active liquidations PAUSED
- Step 3: Sentry FATAL alert fired — ops team notified via SMS and email
- Step 4: Ops confirms custody provider status via status page and direct support contact
- Step 5: No liquidations proceed until custody provider API confirmed available
- Step 6: Once custody provider available — Tier 3 human authorization obtained — liquidations resume
- Step 7: Post-incident review — all paused liquidations reviewed for LTV status — escalation decisions documented

4.3 Security Incident — Unauthorized Access Attempt

- All webhook endpoints require HMAC-SHA256 signature validation — unauthenticated requests rejected with HTTP 401 and logged
- All internal API endpoints require JWT authentication — expired or invalid tokens rejected
- Static IP whitelisting on Railway (208.77.244.15) — requests from unlisted IPs blocked at network layer
- Redis rate limiting on all endpoints — excessive request rates trigger automatic throttling
- If unauthorized access confirmed: rotate all secrets immediately (JWT signing key, HMAC webhook secret, API credentials), audit all recent LiquidationEvents for unauthorized activity, notify affected credit union within 24 hours

4.4 Monitoring & Alerting Infrastructure



Sentry error monitoring is active across all 4 Aetherum projects (backend, frontend, DACS agent, loan-calc agent). Alert thresholds:

- FATAL: Immediate SMS + email to ops — P0/P1 incidents
- ERROR: Email to ops — reviewed within 4 hours
- WARNING: Logged — reviewed at next business day

Keep-alive service pings backend health endpoint every 4 minutes to prevent Railway cold starts. If health check fails — Railway auto-restarts the service and Sentry logs the restart event.

05 — CONTACT & ESCALATION DIRECTORY

Role	Contact	Escalation Level
Aetherum Founder / Primary Contact	John Bailey II — jbailey@aetherum.ai	All incidents
CU Risk Officer	Configured per CU deployment — ALERT_RISK_OFFICER_EMAIL / PHONE Railway env var	Tier 2 + Tier 3 escalations
Custody Provider Support	Enterprise support channel configured in custody provider account settings	P0 — custody API unavailable
Railway Infrastructure	status.railway.app — enterprise support channel	P1 — infrastructure failures

Document Control — This document is version 1.0, issued May 27, 2026. It will be reviewed and updated at each major platform release and prior to first credit union pilot go-live. SOC 2 Type II audit and formal penetration test will be commissioned at first CU pilot signing — those reports supersede relevant sections of this document upon completion.

Aetherum, Inc. · jbailey@aetherum.ai · aetherum.ai · aetherum.ai/ddq